

Aliro

一、Aliro的定位与简介

Aliro是一个设计成为工程标准的访问凭证与通讯协议。它的目的是用户可以使用移动终端设备（如手机手表等）执行Aliro协议，与电子门锁等IOT终端设备进行交互，来实现安全的访问控制。目前，Aliro具有认证功能的核心模块围绕以ECDSA与ECDH为组件的AKE协议进行。这个执行AKE的模块在Aliro中叫做标准加速阶段（standard expedited phase），该模块的目标是让用户向受访问终端证明自己持有一个密钥，且已知这个密钥与访问控制权限绑定，受访问控制终端就可以根据这个密钥做访问控制决定，执行通过或者终止访问等最终响应。

二、Aliro的身份认证模块与当前的标准认证流程

2.1 初始化

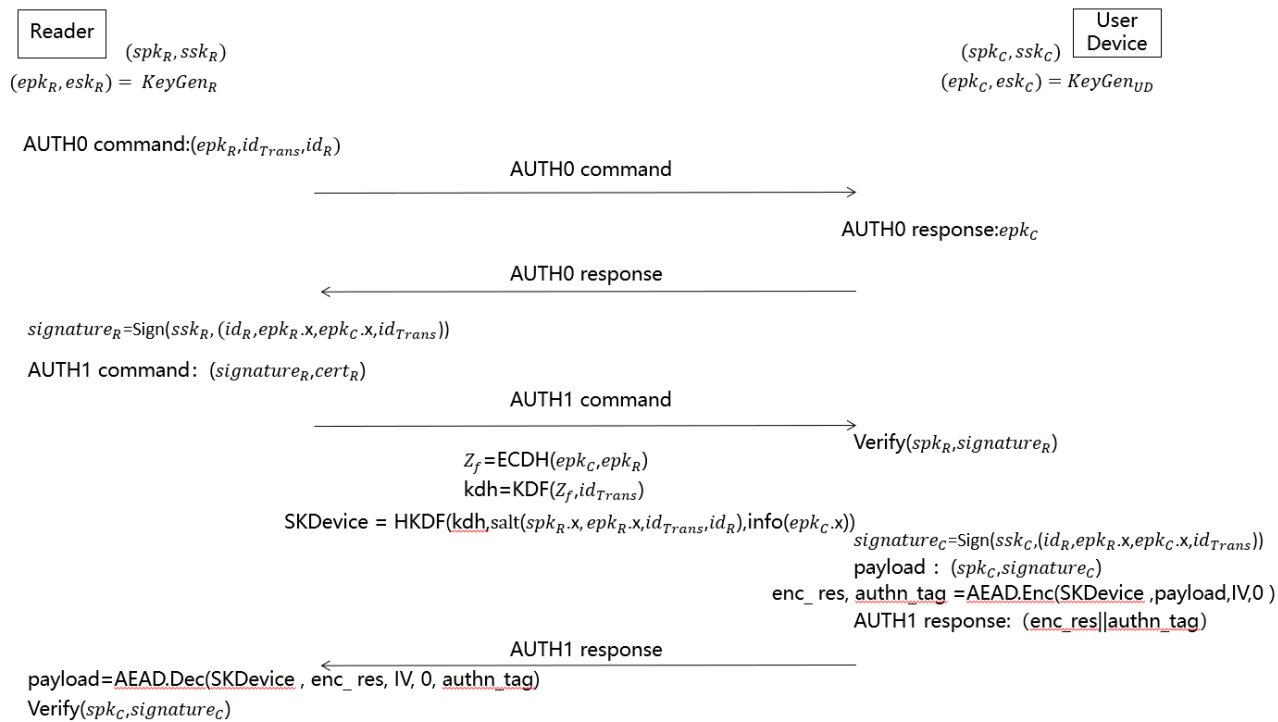
参与认证模块的一共有三个主体，分别是用户持有的设备（User Device，简称UD），受访问的IOT终端（Reader，简称R），以及凭证颁发者（Credential Issuer，简称CI）。

在整个系统的初始化阶段，UD与R都会生成一对长期密钥，且交由他们共有的同一个可信的CI签名并产生各自的公钥证书。同时，CI把UD对R的访问权限信息与UD持有的公钥通过产生一个叫做访问凭证（Access Document）的消息结构绑定在一起。访问凭证是公开信息，可以被R获取。

R通过密钥协商与签名验证来判断一次会话中的UD是否真的持有Access Document中公钥所对应的私钥，若判断为是，则执行Access Document中所记录的权限，否则终止对话。

2.2 加速标准阶段

原Aliro的认证模块协议如下图，R与UD分别持有一对长期密钥，每次会话时生成一对临时密钥。AUTH0阶段R产生一个会话id，并与自己的id以及临时公钥 epk_R 发送给UD，UD返回自己的临时公钥 epk_C 。R收到响应后使用长期公钥 ssk_R 签名，签名内容是R的id，会话id以及双方临时公钥中的x值。AUTH1阶段，R将签名与自己的公钥证书发送给UD。UD验证证书后使用R的公钥验签。以上过程没有终止的情况下，双方通过对两个临时公钥做ECDH产生临时共享秘密 Z_f ，将会话id与 Z_f 作为输入产生中间值 kdh ，使用HKDF派生出最终密钥，截断不同部分的最终密钥作为一系列不同阶段的会话密钥。拥有会话密钥后，UD使用长期公钥对同一消息进行签名，并将公钥与签名作为明文通过会话密钥的安全信道进行传输。R解密并验签，完成认证。



三、后量子化方案

3.1 从工程化出发的后量子改造需求

本工作为了考虑Aliro与PQ-Aliro的工程化落地，目前考虑保留Aliro的部分特征与需求：

- PQ-Aliro也是“命令-响应”的交互模式，认证是由Reader发起，且每个command有且只有只有一条response，response内容可以为空。
- PQ-Aliro尽量保持2RTT形式，尽可能保留Aliro的AUTH0，AUTH1交互形式，以便在工程上实现兼容性。
- PQ-Aliro在保证安全性的情况下尽可能减小通讯尺寸。
- PQ-Aliro使用的后量子组件尽可能使用Kyber，Dilithium这样的NIST标准算法。

3.2 从安全性出发的后量子改造需求

PQ-Aliro在基于标准Aliro的安全性前提下需要有抗量子的安全能力，我们目前想考虑以下部分安全性属性与安全性需求：

- PQ-Aliro应该保持与Aliro一样的双向AKE认证模式。
- PQ-Aliro保持Aliro的显示认证，即沿用签名与身份绑定的模式，不使用KEMTLS那样仅围绕密钥封装提供的身份认证模式。
- PQ-Aliro的会话密钥产生需要有安全的密钥分离。
- PA-Aliro可以满足如BR模型或者其他AKE安全模型的安全性。

我们的PQ-Aliro改造草案中，目前尝试考虑的一些安全属性有：

- 实体认证与身份绑定
- 抗量子攻击性
- 前向安全性
- 抗重放攻击

下图是我们提出的一个后量子化实现草案。

1. R与UD分别持有一对长期密钥。每次会话时R会产生一对用以密钥封装的临时密钥对。
2. 在AUTH0阶段, R生成一个会话id记为 n_{trans} , 与临时公钥 pk_e , id_R 作为命令发送给UD。UD使用 pk_e 进行密钥封装, 得到 S_e 与 S_e , 生成一个响应会话id记为 n_e , 将 n_e 与 C_e 作为响应发送给R。
3. R通过解封装获取临时共享秘密 S_e 。
4. 双方通过哈希AUTH0阶段的消息产生会话记录 $trans_{AH0}$, R使用长期公钥 sk_R 对会话记录签名, 并连同公钥证书 $cert_R[pk_R]$ 作为AUTH1命令发送给UD。
5. UD验证证书, 并使用公钥 pk_R 验证签名。
6. 双方将临时共享秘密 S_e 与会话记录 $trans_{AH0}$ 作为输入, 使用HKDF提取出中间值HS。
7. 使用不同的标记与会话记录绑定, 通过HS派生出两个会话密钥 SK_{Device_R} 与 $SK_{Device_{UD}}$ 。
8. UD使用长期密钥对会话记录签名, 并使用UD的会话密钥 $SK_{Device_{UD}}$ 对公钥与签名加密, 结果发送给R。
9. R使用 $SK_{Device_{UD}}$ 解密并验证签名, 完成认证。

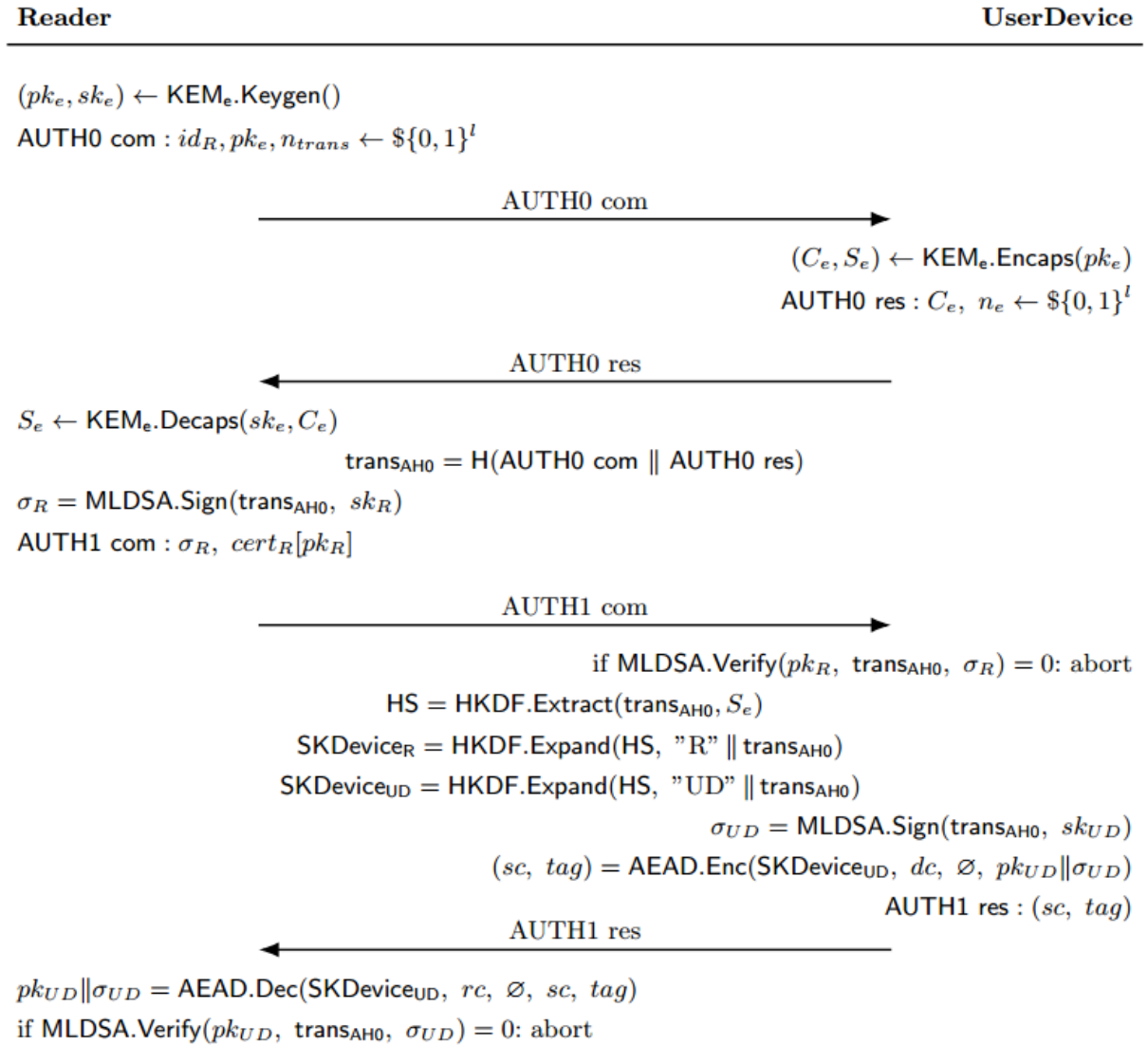


Figure 1: PQ-Aliro Standard-Expedited phase protocol overview.